

PONTIFICIA UNIVERSIDAD CATÓLICA DEL PERÚ
FACULTAD DE CIENCIAS E INGENIERÍA
INGENIERÍA DE TELECOMUNICACIONES



PUCP
Ingeniería de las
Telecomunicaciones

Proyecto Red campus PUCP

Curso:

TEL 354 - Ingeniería de Redes Definidas por Software

Profesores:

Christian Isaac Quispe Ordoñez

Jefe de Práctica Encargado:

Tony Lee Flores

Integrantes del Grupo:

Zuñiga Villaverde, Ariana Carmen

Jaico Balboa, Sheila Abigail

Aldoradin Yaranga, Leonardo

Paucar Valenzuela, Luis Daniel

Valencia Quiroz, Mark

1. Introducción.....	3
1.1. Contexto y problemática.....	3
1.2. Objetivos del proyecto.....	3
1.3. Alcances y limitaciones.....	4
2. Diseño de la red.....	4
2.1. Definición de usuarios y roles.....	4
2.2. Descripción de perfiles de usuarios.....	4
2.3. Nivel de acceso y restricciones.....	5
2.4. Casos de uso.....	5
2.5. Bosquejo de Arquitectura.....	9
2.6. Bosquejo de infraestructura.....	11
3. Diseño de alto nivel (HLD).....	15
3.1. Arquitectura en capas.....	15
3.2. Flujos de trabajo.....	16
3.3. Pipeline de tablas Openflow.....	27
3.4. Escalabilidad del diseño.....	28
3.5. Tablas.....	30
3.6. Casos detallados del Pipeline.....	32
3.7. Reglas OpenFlow por caso.....	36
3.8. Módulos responsables por caso.....	38
3.9. Estados operativos.....	38
4. Diseño de seguridad de la red.....	39
4.1. Modelo de control de acceso y segmentación.....	39
4.2. Ciclo de vida de la conexión.....	39
4.3. Clasificación de recursos y niveles de protección.....	40
4.4. Políticas de seguridad y monitoreo.....	42
4.5. Limitación de amenazas.....	44
4.6. Detección y Mitigación de amenazas.....	45

1. Introducción

1.1. Contexto y problemática

La PUCP cuenta con una población de aproximadamente 31,590 alumnos, 3,122 docentes y 3,021 administrativos. Esta comunidad interactúa diariamente a través de una infraestructura compleja que comprende 13 unidades académicas, 9 bibliotecas, 47 laboratorios y 17 centros de investigación. Al tratarse de una red de alta demanda, es imperativo contar con mecanismos de seguridad que garanticen la disponibilidad, escalabilidad y confiabilidad de los servicios.

Actualmente, las arquitecturas de red tradicionales enfrentan dificultades para gestionar dinámicamente el acceso y proteger recursos críticos ante amenazas internas. Existe una vulnerabilidad latente ante riesgos de seguridad como ataques de DDoS, Man-in-the-Middle e IP spoofing. Específicamente, la intranet se ve expuesta a ataques encubiertos como Network scanning y Port scanning, así como a bots que saturan servidores mediante solicitudes maliciosas.

Frente a esta problemática, se propone una solución basada en SDN que permita centralizar la administración de la red y realizar un análisis apropiado del tráfico para monitorear, detectar y mitigar estos riesgos. La solución busca controlar el acceso según el rol de cada usuario (R1), restringir el acceso a recursos privilegiados (R2) y detectar amenazas internas (R3), garantizando una protección integral del sistema.

1.2. Objetivos del proyecto

En el presente informe se busca diseñar e implementar una solución basada en SDN para una red de campus que permita controlar el acceso según el rol del usuario, proteger recursos privilegiados y detectar y mitigar automáticamente ataques internos, garantizando la seguridad y disponibilidad de los servicios.

La solución debe cumplir con los siguientes requerimientos:

- R1: Controlar el acceso a la red de los usuarios válidos, acorde con su rol.

- R2: Restringir el acceso a recursos privilegiados solo a usuarios autorizados.
- R3: Detectar y mitigar ataques encubiertos en la intranet.

1.3. Alcances y limitaciones

El alcance funcional de la solución contempla la gestión de identidad, la restricción de recursos y la mitigación de amenazas internas (R1, R2 y R3). Si bien el diseño arquitectónico es modular y garantiza interoperabilidad necesaria para incorporar defensas contra ataques volumétricos (R4) y seguridad perimetral (R5), dicha expansión se limita exclusivamente al plano de diseño conceptual dentro de esta entrega

Asimismo, debido a las limitaciones de recursos del entorno virtualizado y la capacidad de procesamiento de los switches virtuales (OVS) asignados, la implementación física y la validación de métricas se realizan sobre un escenario controlado de 3 a 5 hosts.

2. Diseño de la red

2.1. Definición de usuarios y roles

La gestión de acceso se basa en un modelo de Control de Acceso Basado en Roles (RBAC), complementado con el enfoque de Confianza Cero (Zero Trust), bajo el cual ningún usuario o dispositivo es considerado confiable por defecto, independientemente de su ubicación en la red.

2.2. Descripción de perfiles de usuarios

Se definen cuatro perfiles principales, cada uno asociado a un nivel de confianza escalonado:

- Visitantes: Persona externa a la institución que requiere conectividad temporal.
- Estudiante: Persona matriculada en la universidad.
- Docente: Personal académico encargado de la enseñanza dentro de la universidad.
- Administrador de TI (SuperAdmin): Personal técnico responsable de la operación y seguridad de la infraestructura.

2.3. Nivel de acceso y restricciones

Rol	Nivel de Confianza	Acceso a Red	Restricciones Específicas
Visitante	Nivel 0	Internet externo con ancho de banda limitado	Sin autenticación institucional; sesión temporal; sin acceso a intranet ni recursos internos
Estudiante	Nivel 1	Intranet Académica: Aula Virtual, Correo Institucional, Bibliotecas Digitales, Laboratorios Virtuales	Sin acceso a sistemas de gestión docente ni infraestructura de red
Docente	Nivel 2	Intranet Académica completa + Sistema de Gestión de Cursos + Registro de Notas (acotado a sus cursos asignados)	Sin acceso a infraestructura de control de red, consola SDN ni bases de datos administrativas globales
Administrador de TI	Nivel 3	Infraestructura de Control SDN: consola de gestión, switches, logs de tráfico, base de datos de credenciales	Sin acceso a recursos académicos; todas las acciones son auditadas y registradas

Tabla 1 - Acceso por rol

2.4. Casos de uso

En esta sección se describe cómo se da la interacción entre los diversos usuarios y el sistema con la finalidad de posteriormente plantear una solución. En estos se describen casos que comprenden las acciones del usuario con el sistema.

2.1 Requisito 1: Control de acceso a la red

- Estudiante:
 1. Conecta su laptop a la red y accede al portal de autenticación
 2. Escribe mal su contraseña en el portal.
 3. Al inicio de semestre accede por primera vez con sus credenciales recién otorgadas.

4. Comparte sus credenciales con un compañero y ambos se conectan a la vez.
- Docente:
 1. Ingresa al aula para dictar su clase y enciende su PC.
 2. Enciende su PC en la sala de profesores y se autentica con sus credenciales.
 3. Olvida cerrar su sesión en un equipo de la universidad y otro usuario intenta usar su cuenta.
- Invitado:
 1. Un expositor solicita a TI acceso temporal a la red para realizar su presentación
 2. Las credenciales temporales de un invitado vencen y el sistema revoca el acceso de forma automática.
 3. Un externo intenta acceder a la red con credenciales robadas o prestadas.
- Admin TI
 1. En un nuevo inicio de semestre se deben cargar todas las credenciales de las cuentas para los nuevos alumnos o personal al sistema.
 2. Un docente ya no forma parte de la universidad y es necesario retirar sus credenciales para el acceso.
 3. Se da un cambio a nivel de la organización y es necesario actualizar las políticas por rol.
 4. En su revisión detecta un intento fallido constante de un usuario y la marca para su revisión.

2.2 Requisito 2: Restricción de acceso a recursos

- Estudiante:
 1. Intenta abrir la URL del panel de administración de la red.
 2. Accede al aula virtual y descarga materiales de sus cursos.
 3. Dentro de los participantes de un curso intenta ver qué otros cursos lleva uno de sus compañeros.
- Docente:
 1. Ingresa al repositorio de tesis para hacer una revisión de un trabajo de investigación.
 2. Intenta revisar los usuarios que accedieron a un recurso del repositorio y se bloquea su acceso
 3. Registra y modifica las notas de un examen de sus alumnos en el sistema.
- Invitado:
 1. Intenta navegar hacia servidores académicos internos (biblioteca, registros de alumnos).
- Admin TI

1. Accede a la consola de gestión para hacer cambios en la configuración de los switches.
2. En una auditoría revisa los logs fallidos internos hacia recursos críticos para verificar si se trata de un ataque.
3. Ocurre una falla en la red y es necesario reconfigurar un switch o se necesita actualizar una regla en el controller.
4. Hace una consulta de los usuarios que modificaron un registro académico.

2.3 Requisito 3: Detección y mitigación de ataques internos

- Estudiante / usuario comprometido:
 1. Infecta una PC de un laboratorio y esta empieza a enviar varios paquetes a múltiples servidores internos
 2. Modifica su dirección IP manualmente con el fin de usar la de un docente y acceder al portal de notas.
 3. Su equipo es parte de un conjunto comprometido y empiezan a bombardear de paquetes el portal de notas.
 4. Durante el período de matrículas, equipos infectados bombardean la intranet.
- Docente:
 1. Su PC de la universidad está comprometido y genera tráfico hacia diferentes servidores.
 2. Un atacante usa su IP para acceder a recursos permitidos a su rol como el portal de alumnos, repositorio personal o acceso a notas.
 3. Durante la noche su equipo, infectado, empieza a generar tráfico saliéndose del patrón de uso habitual.
- Admin TI:
 1. Recibe alertas de ataques como port scanning y accede al panel de incidentes para verificar si es un falso positivo o no.
 2. A un docente se le impidió por error acceder al portal de intranet, entonces se revocó ese bloqueo.
 3. Implementa nuevas reglas respecto a un flujo legítimo que generaba falsas alertas.
- Invitado:
 1. Su laptop infectada se conecta a la red e inicia un ataque a la red.

2.4 Requisito 4: Detección y mitigación de ataques DDoS

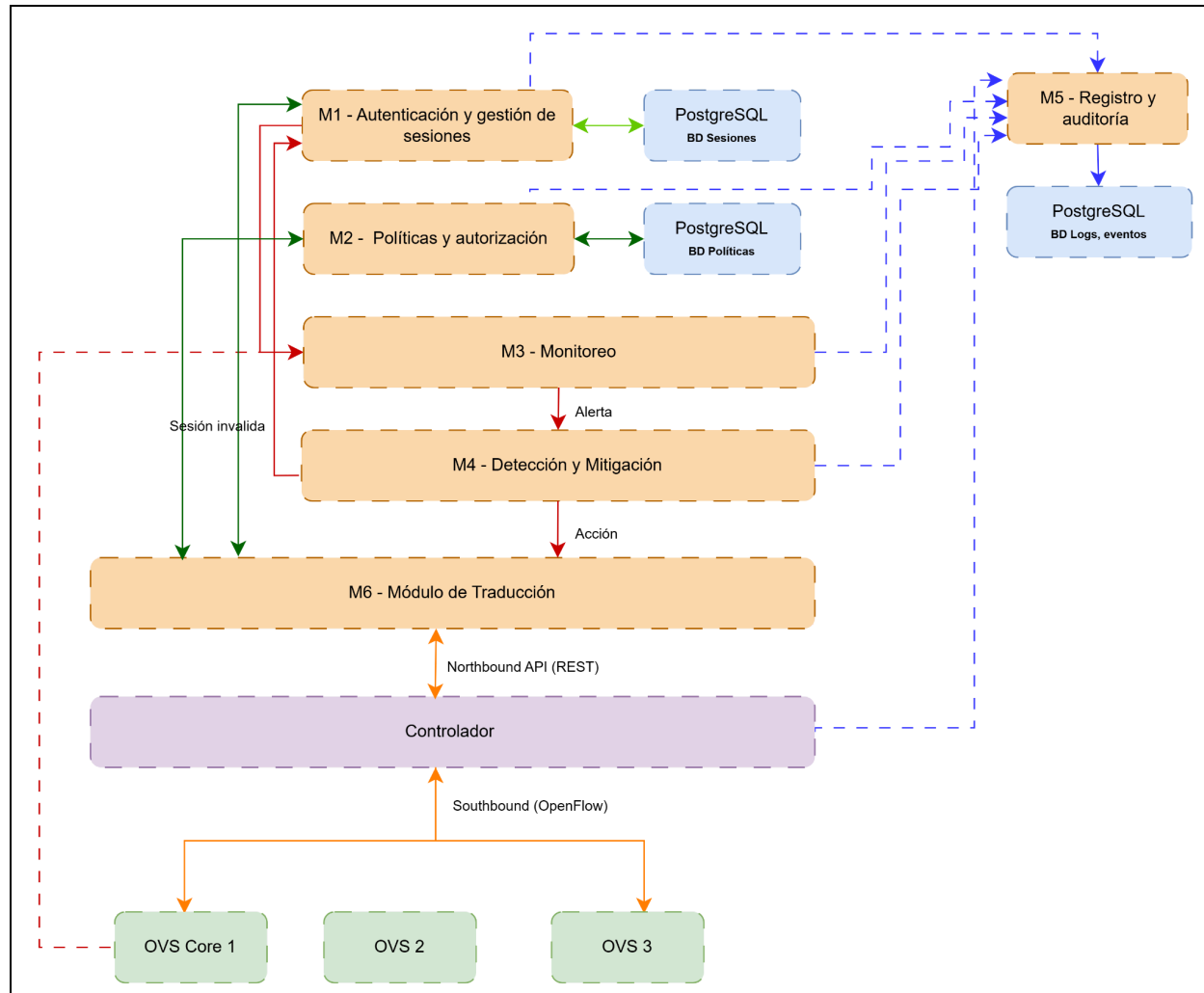
- Estudiante / usuario comprometido
 1. Durante el período de matrículas su equipo está comprometido y satura el servidor.

- a. Usa un script de contraseñas para intentar acceder a la cuenta de un profesor.
- Invitado
 1. Un invitado conecta su equipo a la red de la universidad e inicia un ataque brute-force hacia el portal de autenticación para acceder a la red completa.
- Admin TI
 1. Recibe una alerta del tipo DDoS hacia el servidor de autenticación y aplica un rate-limit a las pcs de los usuarios detectados como atacantes.

2.5 Requisito 5: Protección perimetral contra ataques externos

- Estudiante
 1. Al descargar un archivo de una página web catalogada como no segura, se empieza la descarga de un archivo malicioso pero es bloqueado antes de culminar.
- Invitado
 1. Enviar exploits desde Internet a la página web o al correo de la universidad.
 2. Mediante una IP Zombie realiza un escaneo de puertos en el perímetro de la red campus.
- Admin TI
 1. Crea y modifica listas negras de IPs y URLs externas.
 2. Detecta un nuevo patrón de ataque desde el exterior y añade nuevas reglas que se aplican al perímetro.

2.5. Bosquejo de Arquitectura



M1 - Gestión de Identidad:

Es el punto de entrada a la red. Su función es verificar que el usuario sea legítimo: recibe sus credenciales a través del Portal Cautivo, las valida contra la base de datos, y determina el rol que le corresponde (Invitado, Estudiante, Docente o Admin). Con ese rol, crea una sesión activa que vincula al usuario con su dirección IP y MAC address.

Una vez creada la sesión, M1 opera en dos direcciones. Por un lado, notifica a M6 con el rol asignado para que este traduzca la instrucción y el Controlador SDN instale las reglas de acceso correspondientes en los switches. Por otro, sincroniza la sesión activa con M3 para que el módulo de monitoreo pueda asociar cada dirección IP con un usuario autenticado. Adicionalmente, M1 puede recibir órdenes de M4 para revocar una sesión si se detecta comportamiento sospechoso, dejando al usuario sin acceso a la red aunque sus credenciales sigan siendo válidas. Todos sus eventos quedan registrados en M5.

M2 - Políticas y autorización :

Es el módulo encargado de definir y gestionar las políticas de acceso de la red. Almacena las reglas asociadas a cada rol, especificando los recursos, servicios y condiciones de acceso permitidos. Estas políticas se mantienen en una base de datos y pueden modificarse sin afectar directamente la configuración de los dispositivos de red.

Su operación es bajo demanda. Cuando el Controlador SDN recibe un paquete para el cual no existe una regla previa (evento packet-in), consulta a M2. Este evalúa la solicitud en función del rol del usuario y responde con una decisión binaria: permitido o denegado. En base a esta respuesta, el controlador instala o descarta la regla correspondiente en los switches. Todas las decisiones son registradas en M5, garantizando trazabilidad y soporte para auditoría.

M3 - Monitoreo:

Es el módulo encargado de analizar el comportamiento del tráfico interno de la red. Recibe una copia del tráfico desde los switches sin afectar el flujo de datos, lo que permite realizar inspección de manera transparente.

Su capacidad se apoya en la tabla de sesiones proporcionada por M1, lo que le permite asociar direcciones IP con usuarios autenticados y diferenciar entre tráfico legítimo y potencialmente malicioso. Cuando identifica patrones anómalos, no actúa directamente sobre la red, sino que genera alertas estructuradas que son enviadas a M4 para su evaluación. Todos los eventos son registrados en M5.

M4 - Detección y mitigación :

Es el módulo de respuesta activa ante amenazas. Recibe las alertas generadas por M3 y las somete a un proceso de correlación: analiza si múltiples alertas de un mismo origen en un intervalo corto de tiempo configuran una amenaza real, evitando actuar sobre falsos positivos aislados.

Una vez confirmada la amenaza, M4 responde por dos vías simultáneas. La primera es instruir a M6 para que el Controlador SDN instale una regla de alta prioridad sobre el tráfico del atacante, que puede bloquearlo completamente, limitar su velocidad de envío para contener un ataque de saturación, o aislarlo de la red. La segunda es ordenar a M1 que invalide la sesión del usuario comprometido, de modo que pierda el acceso a la red de forma inmediata. Todas las acciones ejecutadas quedan registradas en M5.

M5 - Registro y auditoría :

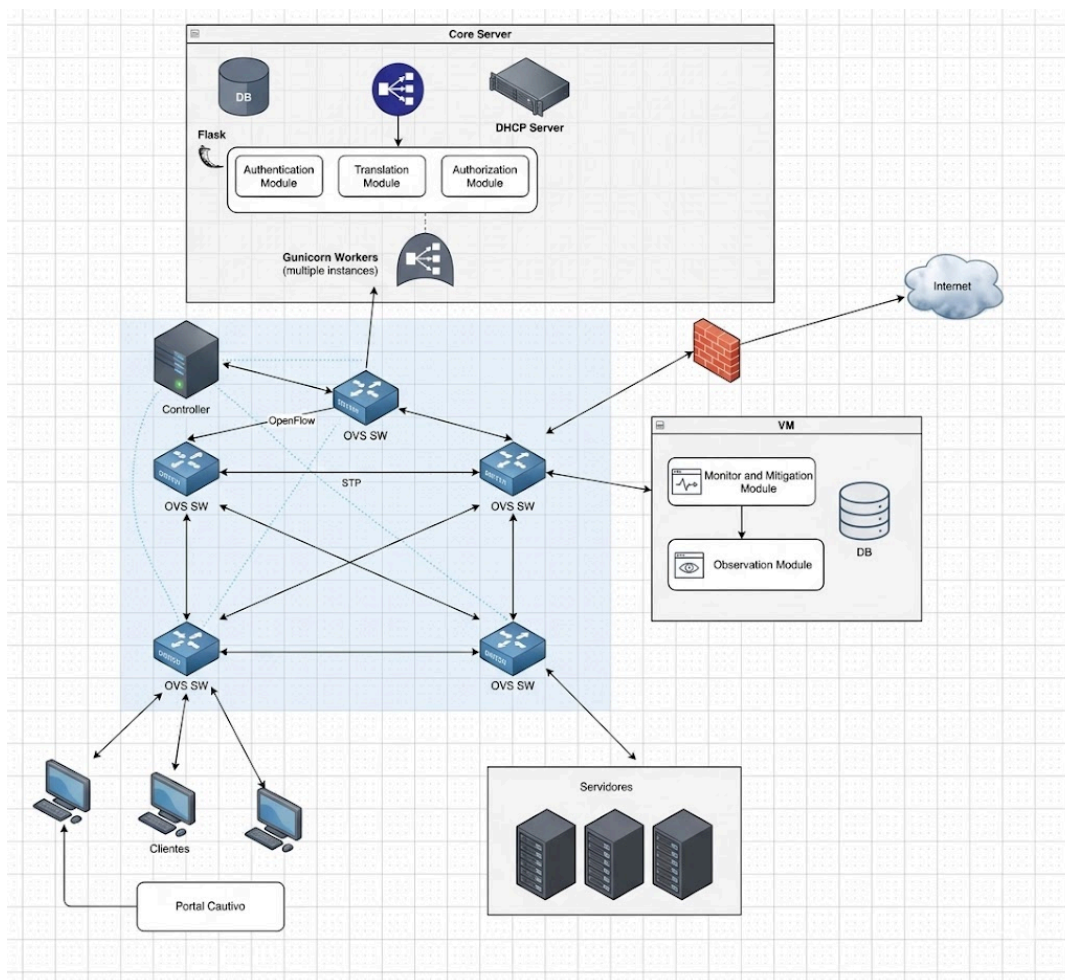
Es el módulo transversal de la arquitectura. No interviene en ninguna decisión ni en la operación de la red; su función es exclusivamente pasiva: centralizar y almacenar todos los eventos generados por los demás módulos y el Controlador SDN.

Registra autenticaciones exitosas y fallidas de M1, decisiones de autorización de M2, alertas de detección de M3 y acciones de mitigación de M4, junto con la marca de tiempo exacta y los metadatos relevantes de cada evento. Esta información cumple tres propósitos: permite realizar auditorías de cumplimiento, facilita la reconstrucción forense de incidentes, y sirve como base histórica para calibrar los umbrales de detección de M3 y M4. Su contenido es accesible desde el Dashboard del Super Admin.

M6 - Módulo de traducción

Actúa como puente entre la lógica de aplicación y el Controlador SDN. Traduce instrucciones de alto nivel, como asignación de roles, autorización de accesos o bloqueo de direcciones IP, en comandos que el controlador ejecuta sobre los switches mediante su API. Este desacoplamiento permite que los módulos operen sin depender de detalles del plano de datos, facilitando el mantenimiento y la evolución del sistema ante cambios en el controlador SDN.

2.6. Bosquejo de infraestructura



1. Desacoplamiento del Plano de Seguridad y Observabilidad (VM Dedicada)

Una de las decisiones arquitectónicas más críticas fue ubicar los módulos de Monitoreo/Mitigación y Observación en una Máquina Virtual (VM) completamente independiente del Core Server. Esta separación hace referencia principalmente al factor de gestión del ancho de banda y la prevención de cuellos de botella.

- Aislamiento de Tráfico (Port Mirroring/Duplicación de Flujos): Para que el módulo de seguridad pueda analizar la red en busca de anomalías, es necesario enviarle copias del tráfico real. Este proceso genera un volumen masivo de datos. Si estos módulos estuvieran alojados en el mismo servidor del monolito principal, el tráfico copiado saturaría rápidamente la interfaz de red del servidor.
- Protección de Servicios Críticos: Al aislar la observabilidad en su propia VM, se garantiza que los picos de tráfico de análisis no consuman los recursos de CPU, memoria ni ancho de banda destinados a servicios críticos y de alta demanda como la autenticación de usuarios, el servicio DHCP y el enrutamiento del portal cautivo.

2. Core Server: Monolito Modular y Gunicorn Workers

El Core Server centraliza la lógica de control de acceso y gestión de usuarios mediante una arquitectura de monolito modular desarrollada en Flask.

- Uso de Gunicorn (Workers): La inclusión de Gunicorn como servidor WSGI no es casualidad. Dado que el portal cautivo puede recibir múltiples solicitudes de conexión y autenticación simultáneas, los workers de Gunicorn permiten manejar esta concurrencia de manera eficiente. En lugar de procesar las peticiones en serie (lo que causaría tiempos de espera inaceptables para los clientes), los múltiples workers distribuyen la carga de trabajo, garantizando una respuesta rápida y mejorando la experiencia del usuario final.

3. Servicios Críticos en el Core (DHCP y Base de Datos)

- Servidor DHCP Centralizado: Mantener el DHCP dentro del entorno del Core Server permite una asignación rápida de direcciones IP en cuanto un dispositivo se conecta a la red física, lo cual es el paso previo obligatorio para que el cliente pueda ser redirigido al portal cautivo.
- Servidor DNS, es un componente fundamental para la resolución de nombres de la intranet y opera en conjunto con el Portal Cautivo; cuando un usuario en estado de "cuarentena" intenta navegar hacia una URL externa, el DNS intercepta la consulta y lo redirige forzosamente hacia la IP del portal de autenticación.
- Base de Datos Local (Core DB): La base de datos que maneja credenciales y roles reside junto a los módulos de autenticación para minimizar la latencia de

red en las consultas ya que estarán en la misma VM. Una autenticación rápida es vital para que el controlador SDN reciba la instrucción y modifique los flujos en los switches OVS en tiempo real.

4. Red Definida por Software (Controlador y Switches OVS)

- Controlador SDN: Se eligió ONOS como controlador debido a su arquitectura modular.
- Switches Open vSwitch (OVS): Se eligieron OVS por su compatibilidad nativa con OpenFlow. Operan puramente en el plano de datos, ejecutando las instrucciones del controlador (permitir, denegar, redirigir o duplicar paquetes) a nivel de puerto de forma casi instantánea.

5. Topología de Red: Malla

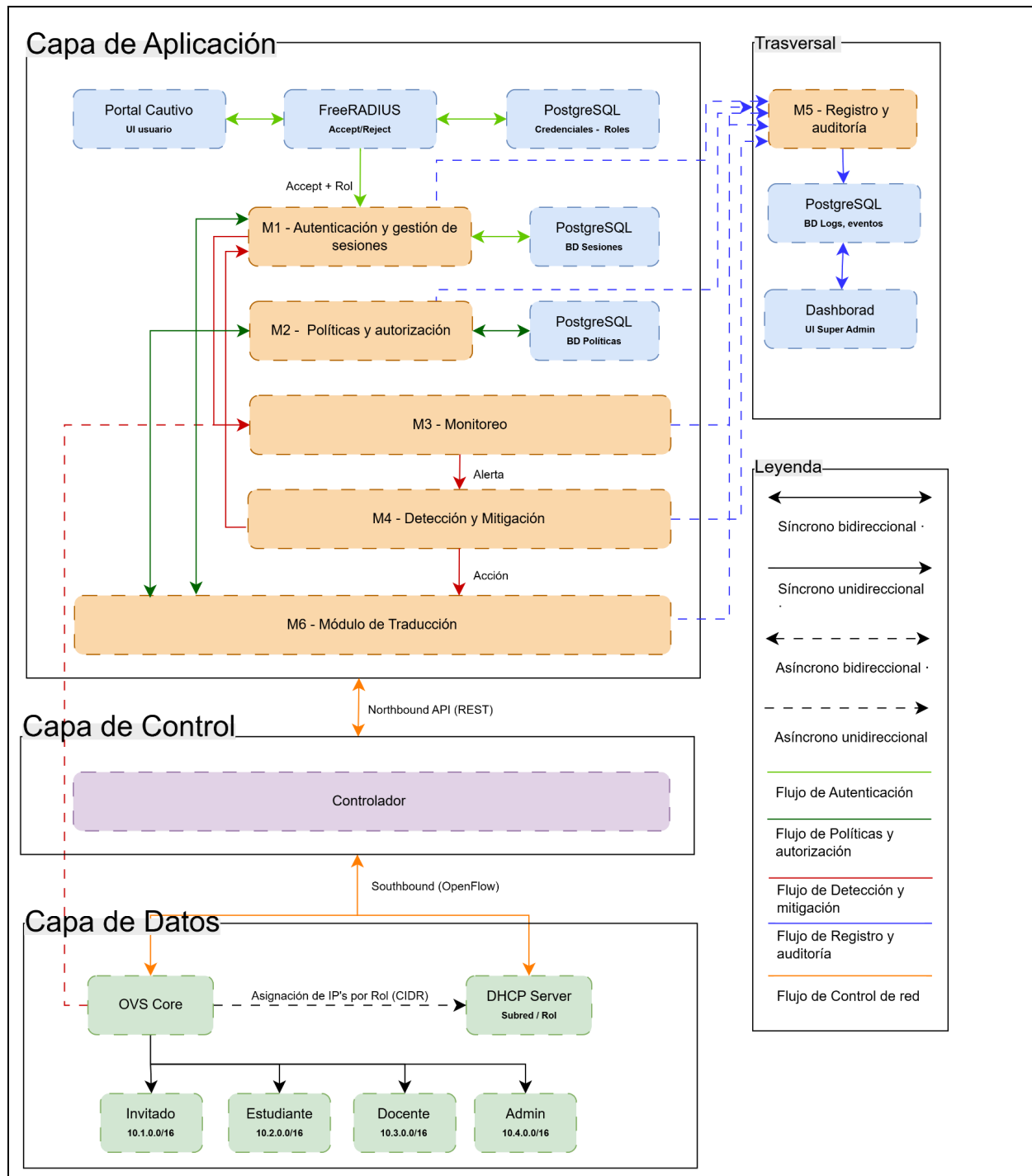
- Topología de Switches: Los switches OVS están conectados en una topología de malla parcial. Esto provee resiliencia y alta disponibilidad. Si un enlace físico falla, existen caminos alternativos para que el tráfico llegue a su destino.
- Spanning Tree Protocol (STP): Para evitar tormentas de broadcast que puedan saturar o tumbar la red, se emplea el protocolo STP en los switches OVS. Esto garantiza una capacidad de recuperación rápida ante la caída de un nodo, manteniendo la red estable y disponible.

Gateway y Firewall:

Para aislar amenazas externas y proteger la red de ataques, todo el tráfico desde internet atraviesa un Firewall perimetral. Este nodo realiza el proceso de NAT stateful y actúa como la primera línea de defensa, bloqueando tráfico malicioso proveniente de IPs externas o URLs categorizadas previamente como peligrosas antes de que ingresen a la red interna del campus.

3. Diseño de alto nivel (HLD)

3.1. Arquitectura en capas



3.2. Flujos de trabajo

F-01: Autenticación del usuario y asignación de su rol

Requerimiento: R1

Objetivo: Permitir a un usuario con credenciales válidas el acceso a la red y los recursos asociados a su rol.

Actor principal: Alumno/ Docente/ Administrador/ TI

Precondiciones:

Usuario registrado en el sistema con un rol designado

La estructura para el acceso a la red está operativa

Evento inicial:

El usuario usa un dispositivo para intentar conectarse a la red del campus.

Flujo principal:

1. El usuario conecta su dispositivo a la red, el Switch al no reconocer el flujo envía un Packet-In al controller.
2. El controller recibe el paquete y lo redirige a M6
3. M6 redirige la petición a M1 para que se autentique el usuario.
4. El usuario ingresa sus credenciales y M1 realiza la consulta en la DB.
5. Al encontrar las credenciales, las válida y determina el rol del usuario.
6. M1 envía un Token de Rol a M6 y sincroniza la sesión activa del usuario con M3 de forma que se controle el tráfico que generará.
7. M6 redirige el token como una solicitud a M2 para saber los privilegios del usuario.
8. M2 responde a M6 enviando las reglas y este las traduce al formato OpenFlow.
9. M6 inyecta la regla en el Controller y este la instala en el Switch.
10. Los módulos que participaron en el evento envían sus logs a M5 para registrarlos por medio de un proceso asíncrono.

Flujo alternativo:

- A1: El sistema de autenticación se encuentra fuera de servicio y el intento de acceso es puesto en espera o rechazado.
- A2: El usuario decide cancelar el request para su autenticación en medio del proceso de conexión, este se bloquea y no le da acceso a la red.

Postcondiciones:

- El usuario es autenticado y se le otorga acceso a la red de acuerdo a su rol.
- El tráfico que recibe y envía es manejado de acuerdo a las reglas para su rol.

F-02: Acceso denegado a usuario por credenciales inválidas

Requerimiento: R1

Objetivo: Restringir el acceso a la red a usuarios que no pasen la verificación de credenciales.

Actor principal: Alumno/ Docente/ Administrador TI

Precondiciones:

La estructura para el acceso a la red está operativa

El usuario inició el proceso de conexión a la red.

Evento inicial:

El usuario ingresa credenciales inexistentes o inválidas a la red.

Flujo principal:

1. El usuario inicia el proceso para conectar su dispositivo a la red.
2. Se le redirige a la interfaz de autenticación (UI) donde ingresa sus credenciales.
3. La solicitud llega al controller que lo deriva a M6
4. M6 realiza la consulta de autenticación a M1.
5. M1 consulta los datos en la DB y al no encontrar las credenciales cataloga la solicitud como error.
6. M1 envía un log (evento asíncrono) a M5 sobre el intento fallido.
7. M1 notifica a M6 que el usuario que ha intentado autenticarse no tiene credenciales válidas.
8. M6 traduce las indicaciones en flujos y las envía al Controller para que este rechace el proceso de autenticación
9. M6 da instrucciones al Controller para que se asegure de tener la regla de DROP para la IP o MAC del dispositivo.
10. M6 registra la acción en M5 de forma asíncrona.
11. Todo acceso a la red y sus recursos es bloqueado para el usuario.

Flujo alternativo:

- A1: M2 envía una política que M6 traduce para indicar al controller que solo permita tráfico del dispositivo hacia el portal de ayuda.
- A2: El usuario repite múltiples veces el intento de conexión por lo cual M6 detecta este patrón en M1 e indica a M4 para marcar la cuenta o dirección IP para revisión.

Postcondiciones:

- El usuario no está conectado a la red..
- El evento queda registrado en los logs para monitoreos o auditorías de la red.

F-03: Asignación de acceso limitado a usuarios invitados

Requerimiento: R1

Objetivo: Otorgar un acceso limitado a los servicios de la red para usuarios invitados evitando mostrar recursos internos.

Actor principal: Invitado

Precondiciones:

Red de invitados activa y funcionando.

Usuario registrado temporalmente o con autorización para emplear la red de invitados.

Evento inicial:

El usuario invitado intenta conectarse a la red del campus.

Flujo principal:

1. El invitado realiza la solicitud a TI para acceder a la red.
2. El administrador genera credenciales temporales en la UI que se almacenan en M1 (quién las almacena en la DB)
3. El invitado accede a la red y el Switch envía un Packet-In al Controller que lo deriva a M6.
4. M6 envía la solicitud a M1 para que realice una validación de identidad.
5. M1 valida las credenciales y devuelve a M6 un token con rol de invitado.
6. M6 redirecciona el token a M2 para consultar los recursos a los que debe tener acceso.
7. M2 responde, con las políticas que se deben aplicar, a M6.
8. M6 traduce las restricciones a reglas OpenFlow y las inyecta al Controller.
9. Controller aplica las reglas al Switch y M6 notifica a M3 la nueva conexión para que sea monitoreado.
10. El invitado emplea la red sin acceder a recursos que tiene restringidos.

Flujo alternativo:

- A1: El tiempo de validez de las credenciales excede y M1 lo detecta y envía una señal a M6 quien ordena al Controller borrar las reglas de flujo para el invitado.
- A2: El invitado intenta acceder a recursos fuera de su rol entonces el Switch no encuentra reglas de permisos a estos por lo cual hace un Packet-In al controller quien envía este a M6 entonces verificando el rol y tipo de recurso al que se quiere acceder, ordena al Controller descartar la solicitud y registra el intento en M5.

Postcondiciones:

- El invitado es autenticado en el sistema pero con permisos básicos.
- El acceso a recursos internos o sensibles es bloqueado completamente.

F-04: Actualización de políticas de acceso o roles.

Requerimiento: R1

Objetivo: Autorizar al administrador TI para la edición y actualización de roles o reglas de acceso sin que estas influyan negativamente en el funcionamiento del servicio.

Actor principal: Administrador TI

Precondiciones:

El administrador está autenticado y con sesión activa en la red. Además posee los permisos necesarios para realizar modificaciones.

Hay políticas de red y roles previamente definidos en la red.

Evento inicial:

Se necesita editar y modificar roles o reglas de acceso debido a cambios organizacionales, recursos a añadir, problemas con el acceso, entre otros..

Flujo principal:

1. El administrador ingresa a la interfaz UI y selecciona un rol o política que desea modificar.
2. UI envía la modificación a M6 quien solicita a M2 actualizar la DB.
3. M2 verifica que la nueva regla no genere problemas o choque con otras políticas y posteriormente actualiza la DB.
4. M2 confirma el cambio hecho a M6.
5. M6 se comunica con Controller para saber que usuarios estan conectados y tienen el rol al que se le realizó la actualización.
6. M6 traduce los nuevos permisos en flujos de actualización (Flow Mod).
7. M6 inyecta los flujos en el Controller y este actualiza las tablas en los switches en tiempo real.
8. Los cambios se evidencian en la red sin intervenir o afectar la conexión de los usuarios a esta.
9. M6 registra la modificación de políticas y los dispositivos a los que se aplico esta en M5.

Flujo alternativo:

- A1: La revisión del sistema sobre las nuevas políticas hecha por M2 presenta conflictos para una regla de seguridad en M4, entonces M2 avisa a M6 y este no realiza inyecciones al Controller y genera una alerta en la UI para mostrarle al administrador con un mensaje que indica lo sucedido.
- A2: El administrador programa la ejecución de las modificaciones en una ventana de mantenimiento, M6 guarda las modificaciones con un timestamp y realiza la traducción y actualización automática en el Controller a la hora indicada.

Postcondiciones:

- Las políticas añadidas son actualizadas para los roles asignados.
- Los usuarios con los roles a los que se le modificaron nuevas políticas operan con estas desde el momento que se ejecutan estas en el sistema.

F-05: Autorización para el acceso a un recurso privilegiado

Requerimiento: R2

Objetivo: Otorgar el acceso de un usuario con los permisos necesarios para que emplee el recurso privilegiado según lo necesite.

Actor principal: Docente/Administrador TI

Precondiciones:

El usuario está autenticado y con la sesión activa.

El recurso al que se desea acceder posee políticas específicas.

Evento inicial:

El usuario desea acceder a un recursos privilegiado en la red..

Flujo principal:

1. El usuario solicita el acceso a un recurso que es identificado como privilegiado.
2. El switch no tiene una regla para ese destino por lo cual envía un Packet-In al Controller.
3. El Controller envía la solicitud a M6.
4. M6 realiza la identificación del rol del usuario con M1 y consulta a M2 si ese rol tiene acceso al recurso crítico.
5. M2 valida que el rol posee permisos sobre ese tipo de recurso y manda una confirmación a M6.
6. M6 traduce la indicación en una regla de autorización con prioridad alta y tiempo de vida.
7. M6 inyecta la regla en el Controller que lo instala en el Switch.
8. El switch permite el tráfico del usuario al recurso.
9. Los módulos involucrados envían un log a M5 (asíncrono).

Flujo alternativo:

- A1: M2 verifica que la IP destino no existe o esta inhabilitada y avisa a M6, este ordena al Controller no instalar la regla y enviar un mensaje de error por indisponibilidad a la UI.
- A2: M2 detecta que el rol del usuario no contiene entre sus políticas el permiso de este al recurso y avisa a M6, este genera una regla DROP y la inyecta al Controller, este aplica la regla al switch quien rechaza el request y M6 graba el intento de acceso en M5.

Postcondiciones:

- El usuario accede de forma exitosa al recurso.

F-06: Acceso denegado a un recursos delicados o críticos

Requerimiento: R2

Objetivo: Impedir que usuarios que no cuenten con los permisos adecuados accedan a los recursos importantes de la red..

Actor principal: Alumno/Invitado/Docente

Precondiciones:

El usuario está autenticado y con la sesión activa pero sin los permisos necesarios sobre el recurso crítico.

Los recursos críticos se encuentran identificados y protegidos con políticas.

Evento inicial:

El usuario intenta acceder a un recurso crítico (administración de la red, etc).

Flujo principal:

1. El usuario solicita el acceso a un recurso catalogado como crítico.
2. El switch no tiene una regla para ese destino por lo cual envía un Packet-In al Controller.

3. El Controller envía la solicitud a M6.
4. M6 realiza la identificación del rol del usuario con M1 y consulta a M2 si ese rol tiene acceso al recurso crítico.
5. M2 verifica en la DB que el rol no posee permisos sobre ese tipo de recurso.
6. M2 envía la respuesta a M6 y este traduce la política en una regla DROP que inyecta en el Controller y este último la instala en el switch. M6 registra el interno en M5 y el usuario recibe un mensaje de error en la UI.

Flujo alternativo:

- A1: El usuario intenta repetidas veces acceder al recurso entonces M6 lo detecta y notifica a M4, este emite una alerta al admin TI. Si la severidad aumenta M6 puede indicar a M4 que bloquee el puerto físico.

Postcondiciones:

- El recurso crítico permanece protegido.
- El acceso se registra en los eventos de seguridad.

F-07: Acceso de administradores TI a gestión de la red

Requerimiento: R2

Objetivo: Otorgar acceso al personal de TI a la infraestructura de gestión de la red procurando la seguridad de esta y el manejo.

Actor principal: Administrador TI

Precondiciones:

El usuario está autenticado y con la sesión activa

Los recursos de gestión de red están definidos y aislados.

Evento inicial:

El usuario desea acceder al panel administrativo.

Flujo principal:

1. El usuario solicita acceso al panel de gestión de la red.
2. El usuario intenta acceder a una IP o puerto restringido.
3. El switch detecta el intento y envía un Packet-In a Controller.
4. Controller reenvía la solicitud a M6 que verifica la identidad del usuario con M1.
5. M6 solicita a M2 que determine si ese rol tiene los permisos necesarios.
6. M2 confirma que el rol pertenece al administrador TI y tiene los permisos.
7. M6 traduce la indicación a un flujo de acceso con prioridad alta y la instala en el Controller.
8. El controller instala la regla en el switch y este otorga el acceso a la zona una vez verificado.
9. El administrador ejecuta las configuraciones o mantenimiento necesario.
10. M6 registra el incidente y las acciones importantes que fueron hechas por el IT en M5.

Flujo alternativo:

- A1: Al rol del usuario se le redujeron privilegios o se le revocó este por lo cual M2 informa a M6 la denegación, entonces por seguridad M6 inyecta una regla de bloqueo en el controller y alerta a M4.

Postcondiciones:

- El administrador accede exitosamente y bajo control a la zona de gestión.
- El evento se registra en los logs del sistema

F-08: Registro y auditoría de eventos de acceso a recursos privilegiados

Requerimiento: R2

Objetivo: Poseer un registro de los intentos de acceso a esta clase de recursos sin diferenciar en el resultado de estos para posteriores auditorías.

Actor principal: Administrador TI

Precondiciones:

El sistema de registro está funcionando sin errores.

Existen recursos en el sistema que se clasifican como privilegiados o críticos.

Evento inicial:

Se realizan diversos accesos o intentos de este a recursos privilegiados.

Flujo principal:

1. Los usuarios realizan solicitudes de acceso a recursos de tipo privilegiado y estos se registran junto a información como la hora, usuario, resultado, recurso.
2. M6 registra datos del evento y la envía a M5 para que la almacene en los logs.
3. El administrador en sus accesos periódicos revisa e identifica si existen patrones de acceso inusuales.
4. El administrador por medio de la UI consulta a M5 para identificar acciones sospechosas por parte de un usuario.
5. Al identificar una amenaza define una nueva política en M2 o una regla para mitigación M4
6. M6 traduce la regla y la inyecta en el Controller para proteger estos recursos.

Flujo alternativo:

- A1: El sistema para el registro de los logs no se encuentra disponible (M5 esta caído) así que M6 pone estos en cola y se almacenan temporalmente hasta que se restablezca este. Entonces M6 realiza un volcado para que no se pierdan estos.

Postcondiciones:

- El administrador cuenta con la información de los accesos para su análisis.

F-09: Detección y aplacamiento de port scanning en la red

Requerimiento: R3

Objetivo: Identificar los intentos de ejecución de un port scanning dentro de la red y aplicar medidas para su mitigación.

Actor principal: Host comprometido

Precondiciones:

El sistema de monitoreo de tráfico está habilitado.

Existen reglas de detección e identificación de port scanning.

Evento inicial:

Un host intenta conectar a diversos puertos en diferentes direcciones en poco tiempo.

Flujo principal:

1. El usuario empieza a intentar conectar a múltiples puertos.
2. El switch al detectar el tráfico inusual envía una copia de este hacia el módulo M3.
3. M3 se encarga de analizar los paquetes e identifica al host que supera el umbral de conexiones por segundo.
4. M3 genera una alerta y la envía a M4 (mitigación).
5. M4 recibe la alerta y emite una instrucción de bloqueo hacia M6.
6. M6 traduce la indicación e instala la regla OpenFlow en Controller y este igual lo hace en el switch afectado.
7. M6 simultáneamente envía la instrucción a M1 de invalidar la sesión del usuario vinculado a esa IP.
8. Los módulos involucrados envían un reporte a M5 de forma asíncrona.

Flujo alternativo:

- A1: El administrador recibe esta alerta de M4 mientras se encuentra conectado, la revisa y crea políticas o realiza acciones que M6 traduce y aplica.

Postcondiciones:

- El host infectado es bloqueado y aislado de la red.
- El intento de port scanning se registra para su posterior auditoría.

F-10: Detección y aplacamiento de ataque de bots

Requerimiento: R3

Objetivo: Identificar ataques donde varios hosts generen un tráfico masivo hacia un único servidor para mitigar el impacto

Actor principal: Hosts comprometidos

Precondiciones:

El sistema de monitoreo de tráfico está habilitado y analizando este.

Existen reglas de detección e identificación de patrones todos-a-uno o anomalías en el servidor.

Evento inicial:

Diversos hosts empiezan a enviar tráfico excesivo a un servidor específico en la red.

Flujo principal:

1. Los hosts envían paquetes o solicitudes masivas a un servidor de la red.
2. El switch envía una copia del tráfico a M3 (mirroring).
3. M3 identifica un volumen masivo de tráfico dirigido a una única dirección destino y alerta a M4.
4. M4 clasifica este accionar como un ataque de bots y aplica un rate limiting o una instrucción de bloqueo completo a M6.
5. M6 simultáneamente, solicita a M1 suspender la sesión de las cuentas asociadas al ataque y traduce la instrucción en reglas OpenFlow de alta prioridad.
6. M6 inyecta las reglas en el Controller y este las envía a todos los switches donde se detectaron los bots.
7. El servidor atacado vuelve a operar con normalidad y M6 envía un reporte a M5.

Flujo alternativo:

- A1: El ataque persiste aún con las políticas y M3 lo detecta por lo cual se alerta a M4 genera reglas del bloqueo completo y las envía a M6 que actualiza el flujo.
- A2: El evento resulta ser un falso positivo y el administrador procede a ajustar las métricas para la detección mediante M6 que ejecuta los flujos en Controller.

Postcondiciones:

- El tráfico malicioso se reduce significativamente o elimina.
- Los hosts maliciosos se aíslan y restringen de la red.

F-11: Detección de IP spoofing interno

Requerimiento asociado: R3

Objetivo:

Detectar intentos de suplantación de direcciones IP dentro de la intranet y responder adecuadamente.

Actor principal: Host malicioso.

Precondiciones:

Existen políticas de asignación y validación de direcciones IP internas.

El sistema de monitoreo puede identificar incongruencias en el uso de direcciones IP.

Evento principal:

Un host interno envía tráfico utilizando una dirección IP que no le corresponde o que genera conflicto con la asignación esperada.

Flujo principal:

1. El host malicioso envía tráfico usando una dirección IP falsificada.
2. El switch detecta el paquete y nota que este no coincide con los reglas de flujo que se tiene en M6 y envía un Packet-In al a M3.

3. M3 detecta la anomalía y la envía a M4 que detecta el patrón de IP spoofing según sus reglas definidas (por ejemplo, duplicidad de IP en diferentes interfaces).

4. M4 emite una alerta con la información del posible origen y el alcance del impacto y la envía a M6.

5. M6 instruye al Controller para instalar la regla en el puerto específico y notifica a M1 para que se bloquee la cuenta del usuario.

6. Controller bloquea al atacante en el switch y se registran los logs en M5.

Flujos alternativos:

- A1. El administrador revisa la alerta y puede descartar el evento si se trata de una situación legítima por medio de M6 quien actualizará los registros en M1 y M2 y borra la regla en el Controller.

Postcondiciones:

- Se reduce el riesgo de suplantación de identidad IP dentro de la intranet.
- El host sospechoso queda bajo restricción o vigilancia adicional.

F-12: Revisión y confirmación de incidente de seguridad

Requerimiento asociado:R3

Objetivo: Permitir que el administrador de seguridad revise, confirme y clasifique los incidentes detectados por el sistema.

Actor principal: Administrador IT

Precondiciones:

El sistema ha generado una o más alertas de seguridad (por ejemplo, por port scanning, bots, spoofing).

Los eventos están registrados y disponibles para consulta.

Evento principal:

El administrador recibe una notificación de nuevo incidente o accede al panel de incidentes para revisión.

Flujo principal:

1. El administrador accede a la interfaz de monitoreo de incidentes que se conecta a M5.

2. El administrador selecciona un incidente registrado para su revisión.

3. El administrador revisa detalles del incidente: origen, destino, tipo de alerta, evidencia de tráfico.

4. El administrador determina si el incidente es válido, un falso positivo o requiere mayor investigación.

5. El administrador clasifica el incidente según su severidad y tipo y este se actualiza en M6 quien inyecta los flujos en el controller.

6. El administrador documenta acciones tomadas o recomendaciones futuras.

Flujos alternativos:

- A1: Si se identifica un falso positivo, el administrador puede ajustar reglas para reducir futuras falsas alarmas y esta instrucción se envía a M6, quien lo

traduce y elimina la regla de bloqueo en Controller. Cuando el admin ajusta los umbrales M6 los modifica en M3 y M4 para evitar incidentes de falso positivo.

Postcondiciones:

- El incidente queda con una clasificación y estado actualizado.
- Se generan insumos para mejorar las políticas de detección y mitigación.

F-13: Revocación de cuarentena por falso positivo

Requerimiento asociado: R3

Objetivo: Permitir que el administrador revierta una acción de mitigación aplicada erróneamente a un host legítimo.

Actor principal: Administrador IT

Precondiciones:

Un host ha sido bloqueado o movido a cuarentena por una alerta de seguridad.

El administrador ha revisado el incidente y lo considera un falso positivo.

Evento principal:

El administrador determina que un incidente clasificado como amenaza es en realidad un falso positivo.

Flujo principal:

1. El administrador accede al listado de hosts en cuarentena o bajo bloqueo, esto por medio de M5.
2. El administrador selecciona el host que se considera afectado por un falso positivo.
3. El administrador revisa los detalles del incidente y confirma que no se trata de un ataque real.
4. El administrador ordena revocar la medida de mitigación (por ejemplo, retirar reglas de bloqueo o devolver el host a su VLAN normal), esto por medio de M6.
5. M6 verifica con M1 si el usuario aún posee una sesión válida y solicita a M2 las políticas originales que le corresponden a ese rol.
6. M6 genera la regla y la inyecta en el Controller y este los actualiza en el switch y el host recupera su conectividad.
7. M6 envía los datos del incidente a M5 y se marca como falso positivo.

Flujos alternativos:

- A1. Si durante la revisión se detectan nuevas evidencias de actividad maliciosa, el administrador puede mantener o endurecer la mitigación en lugar de revocarla.

Postcondiciones:

- El host legítimo recupera su acceso normal a la red.
- El incidente queda marcado como falso positivo en el registro.

F-14: Detección de sesiones concurrentes y credenciales iguales

Requerimiento asociado: R1

Objetivo: Identificar cuando las credenciales de un usuario se usan en más de un dispositivo de forma simultánea y aplicar una regla para proteger al usuario y red.

Actor principal: Alumno/ Docente/ Administrador/ TI

Precondiciones:

Las credenciales del usuario están registradas y activas.

El sistema registra las sesiones activas asociadas a cada cuenta (dispositivo, ubicación, hora) en M1.

Evento principal:

Un segundo dispositivo o punto de acceso intenta autenticarse usando las mismas credenciales de un usuario que ya tiene una sesión activa.

Flujo principal:

1. El usuario A se autentica exitosamente contra M1 y obtiene acceso a la red.
2. M1 registra una sesión activa asociada a la cuenta del usuario A.
3. Un segundo dispositivo intenta autenticarse utilizando las mismas credenciales del usuario A.
4. M1 detecta que ya existe una sesión activa asociada a esa cuenta.
5. M1 aplica la política definida para sesiones concurrentes: permitir la nueva sesión luego de invalidar la anterior.
6. M1 registra el evento en M5 como uso simultáneo de credenciales.

Flujos alternativos:

- A1. Si M1 detecta

Postcondiciones:

Los intentos de uso simultáneo de credenciales quedan registrados y pueden analizarse como posibles abusos o robos de cuentas.

3.3. Pipeline de tablas Openflow

3.3.1 Diseño del pipeline

Tabla	Nombre / Módulo	Función	Acción	Prioridad OF	Quién escribe
T0	Seguridad activa (M4)	Reglas de mitigación ante incidentes confirmados	Drop / Cuarentena / Rate-limit	1000–9999	M4 exclusivo
T1	Verificación de identidad (M1)	Valida binomio MAC+IP con sesión activa. Anti-spoofing.	Avanza a T2 o redirige a portal	100–999	M1 (traducido por M6)

Tabla	Nombre / Módulo	Función	Acción	Prioridad OF	Quién escribe
T2	Política agregada por subred (M2)	Reglas de rol y curso usando CIDR. Longest prefix match nativo.	Output al destino	200–799	M2 (traducido por M6)
T3	Excepción personal (M2)	Reglas por puerto físico para doble rol o permisos únicos.	Output al destino	800–999	M2 (traducido por M6)
T4	Deny-all / table-miss → packet-in	Todo paquete sin permiso explícito. M2 deniega por defecto. Drop rules reactivas viven aquí.	Packet-in → M2 evalúa → drop en T3 o acceso	1	Sistema

Las 5 tablas corresponden a 5 responsabilidades distintas que no se mezclan. T0 es exclusiva de M4 y ningún otro módulo escribe aquí. T4 ya no es una regla estática drop-all: es una configuración table-miss - packet-in.

3.3.2 Flujo de un paquete a través del pipeline

- **T0-Primera consulta:** si el host está bajo mitigación activa (M4), el paquete se descarta o redirige. Sin match, continúa.
- **T1-Verificación de identidad:** se valida el binomio MAC+IP. Sin una sesión activa, el paquete va al portal de autenticación.
- **T2:** hay longest prefix match sobre ip_fuente (CIDR del rol/carrera) + ip_dst (servidor), la regla más específica gana
- **T3:** reglas por puerto físico con prioridad 800–999. Si hay match, se reenvía.
- **T4 table-miss - packet-in:** el paquete llega al controlador. M2 evalúa; si no hay permiso, instala drop rule en T3 con TTL. Flujos subsiguientes ya hacen match en T3 sin generar más packet-in.

3.4. Escalabilidad del diseño

La microsegmentación sin VLANs implementa las políticas de acceso mediante flow entries instaladas directamente en los switches OVS.

OVS en modo software soporta aproximadamente 500,000 entradas limitadas por RAM. El sistema colapsaría sin una estrategia de agregación.

La solución es la sumarización de direcciones IP mediante notación CIDR. OpenFlow 1.3 soporta nativamente el match por prefijo IP (CIDR), lo que permite que una sola regla cubra cientos o miles de hosts simultáneamente.

- Esquema de asignación de bloques IP por rol

Rol / Agrupación	Carrera / Unidad	Bloque IP	Rango de hosts	Máscara	Hosts cubiertos
Alumno	Ingeniería de Telecomunicaciones	10.10.32.0 /20	10.10.32.1 – 10.10.47.254	/20	4,094
Alumno	Ingeniería Civil	10.10.48.0 /20	10.10.48.1 – 10.10.63.254	/20	4,094
Alumno	Derecho	10.10.80.0 /20	10.10.128.1 – 10.10.143.254	/20	4,094
Alumno	Arquitectura	10.10.96.0 /20	10.10.224.1 – 10.10.239.254	/20	4,094
Docente	Todas las facultades	10.20.0.0/17	10.20.0.1 – 10.20.127.254	/17	32,766
Administrativo	Personal de RRHH	10.40.0.0/22	10.20.0.1 – 10.20.15.254	/22	1,022
TI / Superusuario	Administración de red	10.50.0.0/24	10.40.0.1 – 10.40.3.254	/24	254
Invitado	Acceso restringido	10.60.0.0/20	10.50.0.1 – 10.50.0.254	/20	4,094

- Resumen del estado de tablas por caso

Tabla	Caso 1 Proactivo	Caso 2 Reactivo	Caso 3 Internet	Multi-rol	Ataque activo (M4)	Quién escribe
T0	Vacía	Vacía	Vacía	Vacía	ACTIVA Drop/Cuarentena	M4 exclusivo
T1	Sesión registrada	Sesión registrada	Sesión registrada	Sesión registrada	Sesión puede quedar bloqueada	M1
T2	Regla CIDR nueva instalada	CIDR ya existe (rol)	Regla default 0.0.0.0/0	CIDR de rol principal	CIDR activa pero T0 gana	M2 proactivo
T3	—	Excepción instalada si OK	—	Excepciones por puerto	—	M2 reactivo
T4	Drop si sin match	Drop si no autorizado	Drop si sin permiso	Drop si no cubierto	T0 ya bloquea antes	Sistema

3.5. Tablas

- Tabla del switch troncal

Prioridad	Match Fields	Instrucción / Acción	Timeouts
500	ipv4_dst=192.168.10.0/24	Output: Port 48	Permanente
500	ipv4_dst=10.0.1.0/24	Output: Port 12	Permanente
500	ipv4_dst=10.0.2.0/24	Output: Port 15	Permanente
100	eth_type=0x88CC (LLDP)	Packet-In	Permanente
0	*	Drop	Permanente

Para el diseño del switch troncal, la idea principal es que sea lo más rápido posible y por eso no hace validaciones de seguridad complejas. Las reglas principales con prioridad 500 hacen puro enrutamiento rápido de capa 3. El switch solo revisa la subred de destino (ipv4_dst) y saca el paquete por el puerto físico que toca, como el puerto 48 para los servidores o los de retorno a los laboratorios. Aquí se asume que todo lo que llega ya pasó por los filtros Zero Trust en los switches de acceso de los usuarios.

En la prioridad 100 pusimos una excepción solo para el protocolo LLDP. Esta es la única regla en el core que ejecuta un Packet-In hacia el controlador. Esto se hace para que el controlador SDN pueda armar y ver la topología de la red en tiempo real, garantizando que no se sature procesando tráfico normal.

Finalmente, en la prioridad 0 configuramos la regla por defecto o table-miss. A diferencia de los switches de borde donde se envía a evaluar, aquí cualquier tráfico desconocido (*) se descarta directamente. No se consulta al controlador porque en el core no debería haber tráfico sin ruta conocida, evitando así bucles o tormentas de paquetes.

- Tablas del switch de los servidores

T0

Prioridad	Match Fields	Instrucción / Acción
5010	in_port=10, ipv4_dst=IP_BD, tcp_dst=5432	Goto-Table: 1
5000	in_port=10, ipv4_dst=IP_BD	Drop

T1

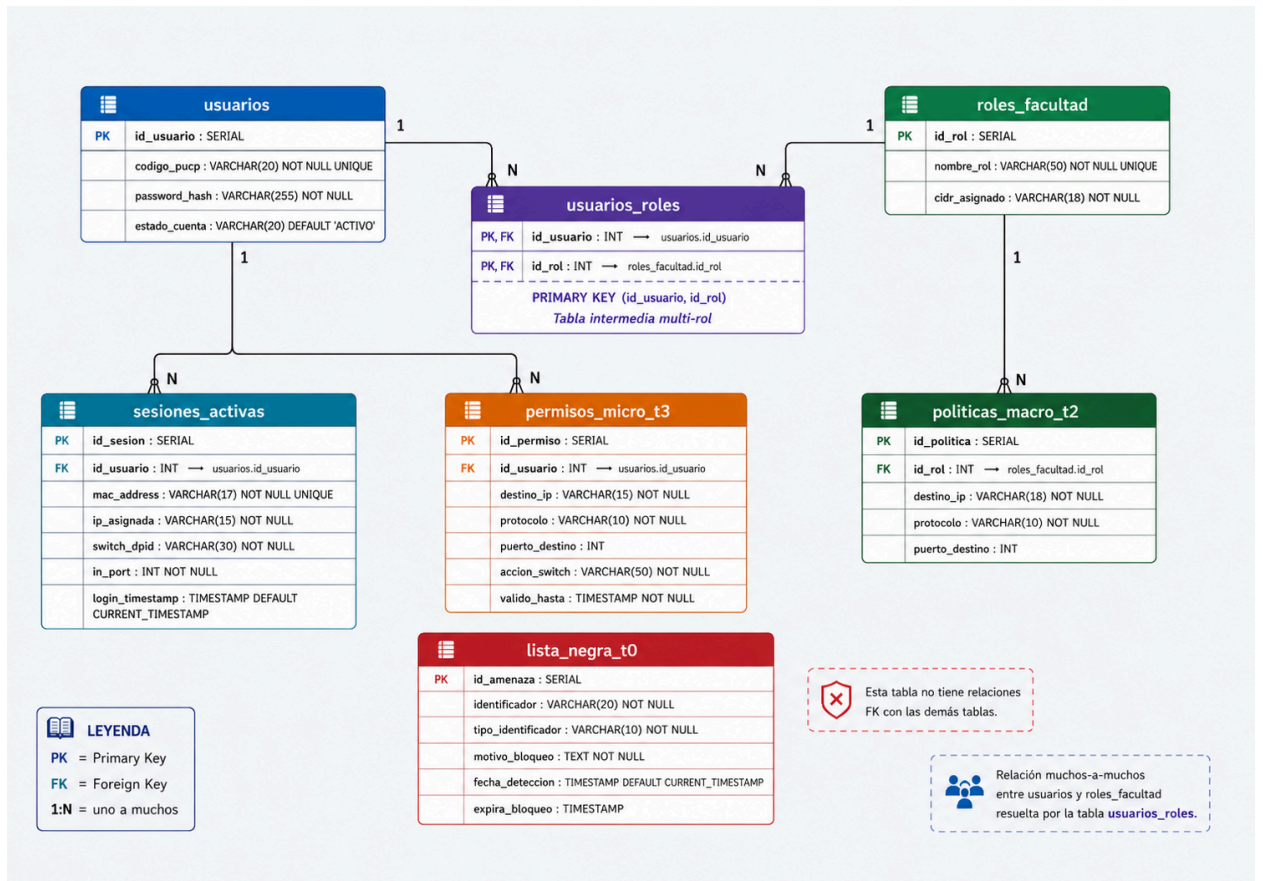
Prioridad	Match Fields	Instrucción / Acción
-----------	--------------	----------------------

500	ipv4_dst=192.168.10.50	Output: Port 10
500	ipv4_dst=192.168.10.51	Output: Port 11
100	ipv4_dst=10.0.1.0/24	Output: Port 48 (Uplink)
0	* (Cualquier)	Drop

Para el switch donde van conectados físicamente los servidores, la configuración se divide en dos tablas. La Tabla 0 (T0) funciona como un seguro interno para hacer microsegmentación y evitar el movimiento lateral si es que hackean un servidor. Acá usamos un truco con las prioridades: la regla 5010 deja que el servidor web (puerto 10) le hable a la IP de la base de datos, pero únicamente por el puerto 5432. Si el servidor web intenta hacer un escaneo o entrar por otro puerto a la BD, hace match con la regla 5000 y se le hace Drop al toque. Así evitamos que se ataquen entre ellos.

Luego el tráfico limpio pasa a la Tabla 1 (T1) que ya hace la entrega final. Como la seguridad ya se validó, acá solo enrutamos. Las reglas 500 mandan los paquetes directo a los puertos 10 y 11 según la IP del servidor que busquen. La regla 100 es para el tráfico de vuelta, para que las respuestas de los servidores regresen a los laboratorios de alumnos subiendo por el puerto 48 hacia el core. Y por si acaso, la prioridad 0 tiene un Drop por defecto si es que llega tráfico perdido.

- Esquema de bases de datos de autenticación y autorización



3.6. Casos detallados del Pipeline

- **Caso 1:** Inserción de reglas proactivas (post-autenticación)

Este caso cubre el proceso que sigue un dispositivo desde que se conecta físicamente hasta que obtiene acceso operativo a la red. Se activa en dos momentos: cuando el sistema arranca y precarga las reglas CIDR por rol y carrera en T2, y cuando un usuario se autentica exitosamente y se instalan sus reglas de sesión.

Flujo detallado

1. El usuario conecta su dispositivo a un puerto del switch de acceso. El switch no tiene ninguna regla de flujo para esa MAC, por lo que genera un evento packet-in dirigido al controlador SDN.
2. Redirección al portal cautivo: El controlador notifica a M6 sobre el nuevo dispositivo. M6 traduce esta notificación en una regla temporal de alta prioridad que se instala en el switch. Esta regla permite al dispositivo
3. Obtener una dirección IP temporal mediante DHCP.
4. Redirigir todo el tráfico HTTP y HTTPS hacia el Portal Cautivo, una interfaz web alojada en el Core Server.
5. El usuario abre su navegador web y es automáticamente redirigido al Portal Cautivo. Allí ingresa sus credenciales institucionales.

6. El Portal Cautivo envía las credenciales a M1. M1 consulta la base de datos en M5 para validar al usuario. Si las credenciales son correctas, M1 obtiene el rol asignado, carrera, etc.
7. M1 entrega a M6 toda la información de la sesión
8. M6 se comunica con el servidor DHCP (ubicado en el Core Server) y solicita la asignación de una dirección IP definitiva correspondiente al bloque CIDR del rol y carrera del usuario
9. M6 solicita a M2 las políticas de acceso asociadas al rol y carrera del usuario. M2 responde con el conjunto de reglas correspondientes. M6 traduce estas políticas a comandos OpenFlow y las inyecta en el controlador, que las instala en el switch de acceso
10. Una vez instaladas las reglas, el usuario tiene acceso a la red según su rol. El primer paquete que genera el usuario recorre el pipeline, T0 sin match (sin mitigación activa), T1 match en sesión, T2 match CIDR, el paquete se reenvía a su destino.

¿Por qué proactivo?

La instalación proactiva de reglas CIDR en T2 (por rol y carrera, no por usuario individual) elimina la latencia del primer acceso. Un estudiante de Telecomunicaciones no necesita generar un packet-in para acceder al servidor de Aula Virtual; la regla que cubre todo el bloque 10.10.32.0/20 ya existe en el switch desde el arranque.

Las reglas de T2 se instalan al arrancar el sistema por M2 (a través de M6). Las reglas de sesión en T1 se instalan por M6 al autenticar a cada usuario.

- **Caso 2:** Inserción de reglas reactivas (acceso a recurso diferenciado)
Ocurre cuando un usuario autenticado intenta acceder a un recurso que NO está cubierto por su regla CIDR de rol en T2 ,por ejemplo, un servidor de laboratorio especializado con acceso diferenciado.

Flujo detallado: acceso autorizado

1. El usuario genera un paquete hacia el destino (ej. 10.200.5.3, Lab de Redes Avanzadas).
2. T0: sin match. T1: match (sesión activa). T2: sin match (destino no cubierto por CIDR general). T3: sin excepción aún.
3. T4: table-miss. El switch genera un packet-in al controlador. No hay drop en este momento, el drop ocurre después si M2 lo decide.
4. M3 registra el evento. El Controller consulta a M2.
5. M2 consulta a M5: ¿el usuario está inscrito en el Lab de Redes Avanzadas? Sí.
6. M2 genera una regla de excepción: match in_port=7, ip_src=10.10.1.15/32, ip_dst=10.200.5.3, action=output:core, TTL=30min.
7. M6 traduce, el Controller instala la regla en T3 con prioridad 850. El Controller también reenvía el paquete original vía Packet-Out.
8. Paquetes subsiguientes hacen match en T3 directamente, sin generar más packet-in.

Flujo detallado: acceso denegado

1. Mismos pasos 1 al 4.
2. M2 consulta a M5: el usuario no tiene permiso para ese recurso.
3. M2 genera una regla de denegación: mismo match, action=drop, TTL=5min, prioridad 840.
4. M6 instala la drop rule en T3. Intentos repetidos ya hacen match en T3 (drop) sin generar packet-in adicionales.
5. M5 registra el intento denegado para auditoría.

- **Caso 3:** Tráfico hacia internet

Cuando un usuario genera tráfico hacia IPs externas (fuera del espacio 10.x.x.x). El longest prefix match de OpenFlow 1.3 distingue tráfico interno de externo sin VLANs ni inspección profunda.

Mecanismo: regla default CIDR en T2

Se instala en T2 una regla con match ip_dst=0.0.0.0/0 (cualquier IP) con la prioridad más baja del rango. Si el destino es una IP interna, la regla más específica de esa IP gana. Si el destino es externo, ninguna regla interna aplica y la regla default lo reenvía al gateway.

Flujo: alumno con acceso a internet

1. Paquete hacia 8.8.8.8 (IP externa).
2. T0, T1: sin bloqueo. Sesión activa.
3. T2: regla 10.10.0.0/16, 0.0.0.0/0, prioridad 100 → output:gateway_port.
4. El paquete llega al gateway. El gateway (firewall perimetral) hace NAT y enruta hacia internet.
5. Tráfico de respuesta desde internet: fluye por el gateway hacia el usuario (NAT stateful). El pipeline SDN solo maneja tráfico Este-Oeste interno; el perímetro maneja Norte-Sur.

Flujo: invitado sin acceso a internet

1. Paquete hacia IP externa. T0, T1: sin bloqueo.
2. T2: no existe regla para 10.60.0.0/20 → 0.0.0.0/0 (invitados no tienen permiso de internet).
3. T3: sin excepción. T4: table-miss → packet-in.
4. M2 consulta M5: invitado no tiene permiso de salida. M2 instala drop rule en T3 con TTL.
5. Los intentos subsiguientes del invitado ya son resueltos por T3 (drop) sin packet-in.

Tráfico inverso (desde internet hacia la PUCP)

Este caso está fuera del alcance del pipeline SDN interno. La red usa IPs privadas (10.x.x.x) no enrutables desde internet. El gateway perimetral con NAT stateful solo permite pasar tráfico de respuesta a conexiones iniciadas desde adentro. Cuando hay conexiones nuevas desde internet son bloqueadas en el perímetro, antes de llegar al pipeline de 5 tablas.

- Caso 4: Usuario con múltiples roles o carreras

El esquema CIDR asigna una sola IP por sesión, y esa IP solo puede pertenecer a un bloque a la vez. Un estudiante que pertenece a dos carreras (por ejemplo, Telecomunicaciones y Derecho, en un programa de doble titulación) no puede estar en dos bloques /20 simultáneamente con el mismo dispositivo.

Mecanismo: separar identidad de dirección IP

La dirección IP es un mecanismo de agrupación para las reglas CIDR de T2, no el identificador de identidad. La identidad real vive en M1 (sesión con todos los roles) y en M5 (base de datos de roles y permisos). El pipeline usa la IP para el caso común eficientemente, y el puerto físico más T3 para manejar permisos adicionales.

- T2 cubre el caso común: rol principal + curso principal: servidores del grupo (CIDR).
- T3 cubre el caso especial: permisos adicionales de roles secundarios: recursos específicos por puerto físico.
- Un solo dispositivo, una sola IP, múltiples niveles de acceso.

Flujo: Proceso de asignación de IP para usuario multi-rol

1. M1 obtiene todos los roles activos del usuario desde M5 al autenticarse.
2. M1 determina el rol principal: el de mayor privilegio, o el elegido por el usuario en el portal.
3. El servidor DHCP asigna una IP del bloque CIDR del rol principal.
4. La regla CIDR de T2 para ese bloque ya cubre el acceso a los recursos del rol principal.
5. Para los permisos del rol secundario o segunda carrera, M2 genera reglas de excepción en T3: match in_port + IP/32 + ip_dst específico, TTL = duración de la sesión.
6. Si el usuario quiere cambiar de contexto principal, cierra sesión y vuelve a autenticarse eligiendo el otro rol. M1 reasigna la IP y reconfigura T3.

Tabla de escenarios multi-rol

Escenario	IP asignada	Cobertura T2	Complemento T3
Alumno 1 carrera, 1 curso	10.10.1.X /24	Regla /24 Curso A + /16 Alumnos	— (sin excepción)
Alumno 2 carreras (Ing + Derecho)	10.10.1.X /24 (carrera elegida)	Regla /24 curso principal + /16 Alumnos	Regla por puerto para servidores de 2da carrera
JP que también es Alumno	10.10.1.X /24 (bloque Alumno)	Regla /24 Curso A + /16 Alumnos	Regla por puerto para recursos JP (aulas, notas)

Escenario	IP asignada	Cobertura T2	Complemento T3
Docente	10.20.X.X /20 (Docentes)	Regla /20 cubre recursos docentes	Regla por puerto para servidores de docencia
Admin con acceso temporal académico	10.40.X.X /22 (Admin)	Regla /22 recursos admin	Regla por puerto TTL corto

- Esquema de bases de datos de registro y auditoría

Para que M1 y M2 puedan tomar decisiones correctas, M5 necesita una estructura relacional que soporte múltiples roles, cursos y recursos por usuario. Esta estructura es requisito para explicar cómo M1 obtiene no solo los cursos sino también los recursos del usuario.

Entidades principales

- Identidades: usuario con credenciales y MAC address registrada.
- Roles: Alumno, Docente, JP, Admin, TI, Invitado. Un usuario puede tener varios.
- Enrollments / Afiliaciones: relación many-to-many entre usuarios y roles, con la carrera o curso y estado activo/inactivo.
- Recursos / Activos: cada servidor o servicio en la intranet, con IP, nivel de sensibilidad y CIDR de subred.
- Permisos por rol: qué roles tienen acceso a qué recursos, con qué política QoS y con qué nivel (lectura, escritura, administración).
- Permisos por curso: qué cursos tienen acceso a recursos diferenciados, y políticas QoS (genera reglas de T2 nivel /24).
- Sesiones activas: MAC, IP asignada, puerto físico, rol principal de la sesión, timestamp de inicio y expiración.

Al autenticarse, M1 hace una consulta que devuelve: todos los roles activos, el rol principal sugerido, los cursos activos y los recursos con permiso diferenciado. Esa información completa es lo que M2 necesita para generar las reglas CIDR de T2 y las excepciones de T3 en una sola operación.

3.7. Reglas OpenFlow por caso

Caso	Tabla	match ip_src	match ip_dst	action	Prioridad / TTL
1 Proactivo	T2	10.10.32.0/20 (Teleco)	10.200.2.5	output:core_port	300 / sin TTL
1 Proactivo	T2	10.10.0.0/15 (Todos los alumnos)	10.200.1.10	output:core_port	200 / sin TTL

Caso	Tabla	match ip_src	match ip_dst	action	Prioridad / TTL
2 Reactivo OK	T3	in_port=7, 10.10.32.45/32	10.200.5.3 (Lab Redes)	output:core_port	850 / TTL=30min
2 Reactivo deny	T3	in_port=7, 10.10.32.45/32	10.200.5.3 (denegado)	drop	840 / TTL=5min
3 Internet OK	T2	10.10.0.0/15 (Alumnos)	0.0.0.0/0	output:gateway	100 / sin TTL
3 Invitado	T4	any	any	drop	1 / permanente
Multi-rol	T3	in_port=7, 10.10.32.45/32	10.200.4.2	output:core_port	850 / sesión
Ataque (M4)	T0	10.10.32.45/32	any	drop	5000 / TTL=10min

- Las reglas de T2 no tienen TTL porque son estructurales del sistema (roles y cursos existen independientemente de las sesiones).
- Las reglas de T3 tienen TTL porque son excepciones temporales ligadas a sesiones específicas.
- Las reglas de T0 siempre tienen TTL corto para evitar bloqueos permanentes por falsos positivos.
- Las drop rules reactivas (Caso 2 denegado) tienen prioridad 840 — ligeramente menor que las de acceso (850) para que una autorización posterior pueda sobrescribir las.

3.8. Módulos responsables por caso

Módulo	Caso 1 Proactivo	Caso 2 Reactivo	Caso 3 Internet	Multi-rol	Ataque M4
M1 Identidad	Crea sesión en T1	Valida sesión activa	Valida sesión activa	Detecta múltiples roles Asigna IP principal	Sesión puede revocarse
M2 Política	Genera reglas CIDR → T2	Evalúa permiso Instala T3	Genera regla default T2	CIDR rol + excepciones T3	No actúa (T0 prevalece)
M3 Monitoreo	Registra nueva sesión	Registra acceso / deny	Registra tráfico externo	Registra sesión multi-rol	Detecta anomalía Avisa a M4
M4 Detección	—	—	Detecta anomalías externas	—	Instala regla T0 con TTL
M5 Auditoría	Log sesión nueva	Log decisión acceso	Log tráfico externo	Log roles asignados	Log incidente completo
M6 Traducción	CIDR → OF flow-mod	Excepción → OF flow-mod	Default route flow-mod	Excepción T3 flow-mod	Drop rule flow-mod

3.9. Estados operativos

Estado 1: Operación normal (sin incidentes)

- T0 vacía. Sin overhead de seguridad.
- T1 entradas con sesiones activas.
- T2 reglas CIDR proactivas.
- T3 excepciones personales.
- T4 configurada como table-miss : packet-in.

Estado 2: Incidente detectado (M4 activo)

- M4 instala 1 a N reglas en T0 con TTL de 5 a 15 minutos.
- Las demás tablas no se modifican. El host queda bloqueado por T0 independientemente de sus permisos en T2 y T3.
- Al expirar el TTL, la regla de T0 desaparece y el flujo vuelve a T1 a T2 a T3 de forma determinista. Sin oscilación.

Estado 3: Fallo del controlador

- Los switches mantienen todas las tablas con las reglas instaladas hasta ese momento.
- Usuarios con sesión activa siguen con acceso según T2 y T3.
- Usuarios nuevos no pueden autenticarse: T1 no tiene regla para ellos y el tráfico cae a T4.
- T4 sigue configurada. La red no queda abierta. Fallo seguro por diseño.

4. Diseño de seguridad de la red

4.1. Modelo de control de acceso y segmentación

Para asegurar la integridad de la red y la privacidad de la información, se han establecido las siguientes condiciones operativas:

- Protección ante accesos no autorizados: El sistema bloquea automáticamente cualquier intento de acceso fuera del nivel autorizado, impidiendo escaladas de privilegios no autorizadas.
- Acceso basado en segmentación de red: Los privilegios se definen a nivel de alcance sobre servicios de red, no sobre funcionalidades internas de aplicaciones. Los recursos se agrupan en no críticos (servicios académicos generales) y críticos (sistemas de infraestructura de red).
- Acceso a Internet: Disponible para todos los roles. Los visitantes tienen acceso restringido en ancho de banda y sin visibilidad hacia recursos internos.
- Perímetros por rol: Cada rol opera dentro de un conjunto fijo de recursos permitidos. El acceso a recursos sensibles está restringido exclusivamente a los perfiles autorizados, sin visibilidad entre niveles.
- Separación de funciones administrativas: El Administrador de TI tiene privilegios orientados únicamente a la infraestructura de red, sin acceso a información académica o datos de usuarios.

4.2. Ciclo de vida de la conexión

El ciclo de vida de la conexión describe las etapas por las que pasa un dispositivo nuevo desde que se conecta a la red hasta que obtiene acceso operativo, permitiendo aplicar controles de seguridad en cada fase.

a. Estado de Inicialización

Todo dispositivo que se incorpora por primera vez a la red entra en un estado de cuarentena. En esta fase, el sistema identifica el puerto del switch al que está conectado el equipo, le permite obtener una dirección

IP y redirige automáticamente cualquier intento de tráfico hacia el portal cautivo. Durante este estado, no se permite el acceso a servicios internos ni externos.

b. Estado de Validación

Una vez redirigido al portal cautivo, el usuario debe definir su nivel de acceso mediante una de las siguientes opciones:

- Acceso institucional: Requiere autenticación con credenciales válidas, permitiendo asignar roles como Estudiante, Docente o Administrador de TI.
- Acceso de cortesía: Permite al usuario acceder como visitante mediante una opción directa en el portal, otorgando acceso limitado únicamente a Internet externo.

c. Estado de Operación

Una vez validada la identidad del usuario o aprobado el acceso como invitado, el sistema elimina las restricciones iniciales y establece la conexión definitiva. En esta fase, el controlador asigna dinámicamente los permisos según el rol del usuario, habilitando únicamente el acceso a los recursos autorizados. A partir de este momento, el sistema mantiene un monitoreo continuo de la conexión para garantizar su estabilidad y seguridad durante toda la sesión

4.3. Clasificación de recursos y niveles de protección

a. Recursos

El modelo empleado por el sistema es el control de acceso basado en roles (RBAC), en el cual cada usuario que posea un rol predefinido puede acceder únicamente a los recursos asociados al mismo. Estos recursos se agrupan entre críticos y no críticos con la finalidad de aplicar políticas diferenciadas de seguridad.

- No Críticos:

Son servicios de uso general orientados a la comunidad académica. Su compromiso afecta la experiencia del usuario, pero no representa un riesgo directo para la integridad de la infraestructura.

Recurso	Descripción	Roles con Acceso
Aula Virtual / Correo	Plataformas de aprendizaje y comunicación institucional.	Estudiante, Docente
Bibliotecas Digitales	Repositorios de material de estudio, investigaciones y tesis	Estudiante, Docente

Laboratorios Virtuales	Entornos de simulación para prácticas académicas.	Estudiante, Docente
Sistema de Gestión de Cursos	Plataforma para la administración de sílabos, asistencia y materiales por curso	Docente
Registro de Notas	Sistema de ingreso y consulta de calificaciones, acotado a los cursos asignados al docente	Docente

Tabla 3 - Clasificación de recursos no críticos

- Críticos

Son componentes cuyo compromiso podría afectar la disponibilidad, confidencialidad o integridad de toda la red. El acceso está restringido exclusivamente al Administrador de TI

Recurso	Descripción	Roles con Acceso
Base de Datos de Credenciales	Identidades y claves de autenticación de los usuarios.	Admin TI
Controlador SDN	Interfaz central de gestión y programación de la red.	Admin TI
Logs y Monitoreo	Registros de actividad para auditoría y detección de ataques.	Admin TI
Infraestructura Física	Switches y cableado que conforman el plano de datos.	Admin TI

Tabla 4 - Clasificación de recursos críticos

b. Niveles de protección

Los recursos de la red se clasifican en dos categorías según el impacto que tendría su compromiso sobre la operación y seguridad del sistema. Esta clasificación determina el nivel de protección aplicado y los roles autorizados para acceder a cada uno.

1. Acceso limitado: conectividad restringida, sin acceso a recursos internos.
2. Consulta: acceso de solo lectura a recursos autorizados.
3. Consulta/Carga: lectura y modificación limitada a recursos propios.
4. Control total: gestión completa del recurso

c. Matriz de interacción rol-usuario

Para garantizar la separación estricta de funciones, la interacción se rige por la siguiente matriz de permisos:

Recurso	Visitante	Estudiante	Docente	Admin TI
Internet Externo	Acceso Limitado	Acceso Total	Acceso Total	Acceso Total (auditado)
Intranet Académica	Bloqueado	Consulta	Consulta / Carga	Bloqueado
Sistemas de Notas	Bloqueado	Bloqueado	Consulta / Carga	Bloqueado
Infraestructura SDN	Bloqueado	Bloqueado	Bloqueado	Control Total

4.4. Políticas de seguridad y monitoreo

a. Modos proactivo y reactivo

La solución implementa los permisos mediante dos modalidades operativas complementarias.

- Permisos Proactivos: se definen en el estado inicial de cada sesión al momento de la autenticación exitosa. El sistema instala reglas de acceso automáticas basadas en el rol, permitiendo que el usuario interactúe con sus recursos académicos sin retardos de procesamiento.
- Permisos Reactivos: Operan de forma continua y en paralelo a la sesión activa. Responden dinámicamente ante comportamientos anómalos o intentos de infracción, actuando como una capa de intervención que ajusta los privilegios en tiempo real sin necesidad de intervención humana.

Modalidad	Recurso	Descripción
Proactiva	Internet Externo	Habilitado para todos los roles al inicio de sesión. Para visitantes, se aplica

		restricción de ancho de banda desde la conexión inicial.
Proactiva	Aula Virtual / Correo Institucional	Habilitado automáticamente para Estudiante y Docente al autenticarse; bloqueado para Visitante y Admin TI.
Proactiva	Bibliotecas Digitales / Laboratorios Virtuales	Acceso otorgado a Estudiante y Docente al inicio de sesión; bloqueado para los demás roles.
Proactiva	Sistema de Gestión de Cursos / Registro de Notas	Acceso exclusivo para Docente, habilitado al autenticarse y acotado a sus cursos asignados.
Proactiva	Recursos Críticos (SDN, BD, Logs, Infraestructura)	Acceso restringido exclusivamente al Admin TI desde la conexión inicial.
Reactiva	Respuesta ante Anomalías	Ante patrones de escaneo, flood o suplantación, el sistema genera dinámicamente una regla de bloqueo para aislar la sesión infractora.
Reactiva	Defensa ante Reincidencia	Múltiples intentos fallidos hacia recursos no autorizados disparan el aislamiento automático del puerto y notificación al Admin TI.

b. Políticas bases

- Mínimo privilegio: Cada usuario accede únicamente a los recursos estrictamente necesarios para su rol.
- Denegación explícita: Cualquier intento de acceso a un recurso fuera del nivel autorizado resulta en el descarte inmediato del tráfico, sin notificación al usuario.
- Validación de integridad de sesión: El sistema verifica continuamente que los parámetros de red de cada flujo activo coinciden con la sesión registrada durante la autenticación. Cualquier inconsistencia desencadena el bloqueo del puerto infractor.
- Control de intentos fallidos: Si un usuario supera tres intentos fallidos de autenticación, el sistema revoca el acceso del puerto correspondiente y aísla temporalmente el dispositivo de la red.

c. Monitoreo de indicadores de red

El sistema supervisa de forma continua indicadores operativos como latencia por flujo, consumo de ancho de banda por sesión y tiempo de vida de conexiones activas. Valores que se desvíen significativamente de la línea base establecida para cada rol son tratados como señales de alerta temprana, alimentando la lógica de detección reactiva antes de que el comportamiento anómalo escale a un ataque confirmado.

4.5. Limitación de amenazas

a. Amenazas conocidas y nuevas

El sistema mantiene una lista de identificadores de tráfico malicioso conocido como las direcciones de origen, patrones de paquetes y firmas de ataque documentadas. El tráfico que coincida con esta lista es bloqueado de forma proactiva en el punto de entrada, sin necesidad de análisis adicionales. Para patrones no reconocidos, el sistema activa la detección reactiva basada en comportamiento, aplicando los mecanismos descritos a continuación.

Para este vector de ataque se sigue la siguiente lógica: *qué detecta* → *qué decide* → *qué hace*

- Port / Network Scanning
El sistema detecta cuando un host genera intentos de conexión hacia múltiples destinos o puertos en un intervalo corto, superando el umbral definido para su rol, o cuando el patrón de tráfico coincide con una firma de escaneo conocida en la lista negra. Decide que el comportamiento corresponde a reconocimiento activo de la red. Como respuesta, bloquea el tráfico originado desde ese host, aísla el nodo y notifica al Administrador de TI.
- IP Spoofing
El sistema detecta tráfico cuya dirección de origen no coincide con la asociación puerto-identidad registrada durante la autenticación, o cuya firma corresponde a un origen malicioso conocido. Decide que el host está intentando suplantar una identidad de red. Como respuesta, descarta el paquete de forma inmediata, invalida la sesión activa y fuerza un nuevo ciclo de autenticación.
- Man-in-the-Middle
El sistema detecta inconsistencias en las asociaciones entre entidades de red y puertos de acceso, por ejemplo, dos puertos reclamando la

misma identidad, o patrones de intercepción documentados en la lista negra. Decide que existe una posible interposición en la comunicación. Como respuesta, aísla ambos hosts involucrados, suspende sus sesiones y registra el incidente para auditoría.

- Flood de solicitudes / Bots Intranet

El sistema detecta ataques volumétricos en el Intranet originados por un host legítimo o comprometido supera el umbral de solicitudes por unidad de tiempo hacia un mismo destino interno, o cuando el perfil de tráfico coincide con patrones conocidos de bots o herramientas automatizadas. Adicionalmente, un incremento sostenido en la latencia o en el consumo de ancho de banda de un destino específico actúa como señal de alerta temprana. Decide el aislamiento del tráfico malicioso en Switch de Acceso. Como respuesta, reduce el ancho de banda disponible para esa sesión y, de mantener máximos, bloquea el flujo por completo y termina la sesión.

En todos los casos, el sistema prioriza la disponibilidad de los servicios: aísla únicamente el nodo sospechoso sin degradar el rendimiento del resto de la red.

4.6. Detección y Mitigación de amenazas

4.6.1. Estrategia de Protección Proactiva (R4)

- Límite de ancho de banda: desde el inicio de la sesión, se aplican límites de ancho de banda diferenciados según el rol autenticado. Estos actúan como techo operativo normal y como línea base de referencia para la detección de anomalías. Un Visitante opera bajo restricción de banda fija, mientras que un Estudiante o Docente tiene acceso proporcional al servicio solicitado. El Administrador de TI cuenta con acceso irrestricto, pero sus flujos son auditados en tiempo real.
- Contención de protocolos y servicios: dado que un usuario no autenticado requiere necesariamente enviar y recibir paquetes ARP, DHCP y HTTPS (portal cautivo) para iniciar el flujo de autenticación, el switch de acceso permite el uso de estos servicios, pero los confina a reglas de flujo con Medidores (Meters). Acción Drop para otros intentos de conexión

Meter	Umbral	Unidad OF	Acción	Función
meter 1	10 pps	PKTS_PER_SEC	Drop	Descubrimient o ARP/DHCP

Meter	Umbral	Unidad OF	Acción	Función
meter 100	512 KBps	KB_PER_SEC	Drop	Acceso a portal cautivo

4.6.2. Mitigación de Ataques Encubiertos y Volumétricos (R3 y R4)

Este requerimiento aborda amenazas de denegación de servicio, descubrimiento de red y suplantación originadas desde el interior de la red, asegurando la estabilidad de la red bajo estrés y seguridad de nodos.

4.6.2.1. Etapa de Monitoreo y Detección (M3)

Se compone de cuatro capas comunicadas sin bloqueo y manteniendo afinidad a hilos:

A. Ingesta

- Recepción de paquetes: la NIC dedicada se configura en modo polling rate, es posible truncar los paquetes a sus cabeceras para reducir consumo de memoria, para construir lotes a partir de ráfagas de paquetes.
- Extracción y parsing de cabeceras: para cada paquete se obtiene una tupla que permite identificar el flujo de manera única.
{IP_origen, IP_destino, Puerto_origen, Puerto_destino, Protocolo}
Se utilizan funciones para decodificar estas cabeceras que minimizan el impacto a este pipeline de ingesta.

B. Agregación

Para cada flujo, se crea una entrada en una tabla hash de tamaño fijo para la dimensión esperada de flujos concurrentes, y se le adjudica un bloque de estadísticas. Se procesan paquetes en ráfagas, si el flujo existe se incrementan sus contadores de paquetes y bytes atómicamente, si no se crea el flujo evaluando si la tabla tiene espacio disponible.

C. Evaluación

Se utiliza un hilo evaluador que itera la tabla completa cada 1 segundo: analiza contadores y los reinicia, incrementa periodos de inactividad o agrega al récord de flujo para su análisis. Al pasar un umbral de 5 segundos sin tráfico analizado se eliminan estos flujos para mantener la tabla hash con flujos activos y espacio disponible.

D. Detección

El hilo evaluador y la agregación absorben el volumen de carga para permitir el análisis de detección. Recibe los récords de flujos, y una señal de flujos dropeados por tabla hash llena, para

procesarlos en ventanas: número de flujos hacia misma IP destino, puerto efímeros con misma IP, baja proporción de flujos con solicitud y respuesta.

```
{
  "title": "M3_Anomaly_Alert",
  "type": "object",
  "properties": {
    "event_id": { "type": "string" },
    "timestamp": { "type": "integer" },
    "anomaly_type": {
      "type": "string",
      "enum": ["UDP_FLOOD", "ICMP_FLOOD", "TCP_SYN_FLOOD", "TCP_PORT_SCAN", "BRUTE_FORCE", "DNS_AMPLIFICATION"]
    },
    "attacker": {
      "type": "object",
      "properties": {
        "ip": { "type": "string", "format": "ipv4" },
        "port": { "type": "integer" } // puerto origen, si aplica
      },
      "required": ["ip"]
    },
    "target": {
      "type": "object",
      "properties": {
        "ip": { "type": "string", "format": "ipv4" },
        "port": { "type": "integer" }, // puerto destino
        "protocol": { "type": "integer" } // número de protocolo IP
      },
      "required": ["ip"]
    },
    "metrics": {
      "type": "object",
      "properties": {
        "measured_pps": { "type": "integer" },
        "measured_bps": { "type": "integer" },
        "unique_flows": { "type": "integer", "description": "Número de flujos distintos del atacante" }
      },
      "required": ["measured_pps", "measured_bps"]
    },
    "severity": { "type": "integer", "minimum": 1, "maximum": 10 }
  },
  "required": ["event_id", "timestamp", "anomaly_type", "attacker", "target", "metrics"]
}
```

Contrato: alerta de anomalía

4.6.2.2. Etapa de Mitigación (M4)

Se compone de 3 capas para recibir alertas de anomalía de M3, un motor de correlación de eventos decide acciones de mitigación de manera automática y proporcional considerando sesiones y roles.

A. Recepción

Consumo alerta de anomalía de M3 para empezar la correlación con otras fuentes de datos u otras anomalías.

B. Motor de correlación

Cada IP de origen de las alertas se analiza con un temporizador para cambiar de estado: se recibe una segunda alerta, umbral de severidad (7), rol sin autorización. Esto último se realiza consultando base de datos para resolver sesión, usuario, rol y privilegios asociados a dicha IP.

C. Mitigación

Se aplica una orden de mitigación proporcional que hereda las especificaciones de granularidad de la alerta e indica acción a realizar. Enviado a M6

```
{
  "title": "M4_Mitigation_Directive",
  "type": "object",
  "properties": {
    "directive_id": { "type": "string" },
    "timestamp": { "type": "integer" },
    "action": {
      "type": "string",
      "enum": ["DROP", "RATE_LIMIT", "INVALIDATE_SESSION"]
    },
    "match": {
      "type": "object",
      "properties": {
        "src_ip": { "type": "string", "format": "ipv4" },
        "dst_ip": { "type": "string", "format": "ipv4" },
        "dst_port": { "type": "integer" },
        "protocol": { "type": "integer" }
      },
      "required": ["src_ip"]
    },
    "parameters": {
      "type": "object",
      "properties": {
        "rate_limit_kbps": { "type": "integer" },
        "duration_seconds": { "type": "integer", "description": "Tiempo de vigencia" },
        "invalidate_session": { "type": "boolean" }
      }
    }
  },
  "required": ["directive_id", "timestamp", "action", "match"]
}
```

Contrato: directiva de mitigación

4.6.3. Seguridad perimetral (R5)

Este requerimiento aborda la protección de la red frente a amenazas originadas desde el exterior, actuando como primera línea de defensa antes de que el tráfico malicioso ingrese a la intranet.

- Lista Negra de IPS y URLs maliciosa

El sistema mantiene una lista negra de IPs y dominios maliciosos o comprometidos. Todo tráfico con origen o destino en esta lista es descartado en el perímetro antes de ingresar a la red interna. La lista negra se debe actualizar de forma dinámica por el Administrador de TI.

- Respuesta activa ante amenaza confirmadas

Cuando el módulo de detección confirma un ataque en curso, el sistema no solo genera una alerta sino que instala automáticamente reglas de bloqueo en el controlador SDN, convirtiendo la detección pasiva en una respuesta activa.

- Aislamiento de tráfico sospechoso

El tráfico externo que no coincida con patrones de ataques confirmado, pero presenta anomalías como volumen inusual, puertos no estándar, es redirigido a una zona aislada donde

se analiza a mayor detalle el tráfico antes de ser permitido o descartado. Esto evita falsos positivos que bloqueen el tráfico legítimo como falsos negativos que permitan amenazas.